Standard: SECURITY-POL00029-STN00032
Driver: Florian Noeding
Data Classification: Internal
Version 11.0

Source Code Security Standard

Contents

1. Overview
2. Scope
3. Statement
   3.1. Users
   3.2. Repository Administrators
   3.3. Organization Administrators
   3.4. SCM System Administrators
   3.5. Utility/Generic Accounts and Automated Workflows
   3.6. Third Party Access
4. Future Revisions
5. Definitions
6. Responsibilities
7. Governing Documentations
8. References
9. Document Properties
10. Document History

1. Overview

This Standard defines the security requirements regarding management of source code at Adobe. In this Standard, a repository refers to a Git repository unless otherwise noted.

2. Scope

This Standard applies to all systems managing source code, their administrators, and users.

3. Statement

3.1. Users

3.1.1 Users must only use Source Code Management Systems (e.g., SCMs) that are compliant with this Standard. The following table lists such systems, with exemplary use cases.

Source Code Management System	Use Cases
git.corp.adobe.com	All, this is a preferred SCM
github.com/enterprises/adobe-prd (with SSO, connected to Okta)	All, this is a preferred SCM
github.com (no SSO, individual accounts)	Open-source software
gitlab.workfront.tech	Only for use by the Workfront team
git.azr.adobeitc.com	Code level collaboration with Adobe's partners, or use cases that need cloud access
Legacy Perforce	Read-only archive

Note: The exception process set forth in Section 6 below must be used for any non-compliant system in use. Once a system is compliant, it can be added to this list.

3.1.2 Production systems affected directly or indirectly by source code must be hosted in an organization-owned repository.

Note: Users may work in user-owned forks of organization-owned repositories if all deployments of this code happen via the organization-owned repository.

3.1.3 Source code changes co-authored by humans must be peer-reviewed before being merged into a primary branch. Fully automated systems are exempt from this requirement – if and only if their own code is subject to human peer review and they make deterministic changes to code (i.e., not LLM / GenAI based) - and may self-approve pull requests as needed or directly commit to a primary branch. A primary branch is the default target branch for all pull requests, often called "main", or any other long-lived branch that is, directly or indirectly, released or deployed to a production system.

Note: This statement captures the intent that a single malicious actor must not be able to submit code changes deployed to a production environment without going through peer review. This does not address the risk that such an actor may attack a continuous integration system via a malicious pull request. This statement is enforced via statement 3.2.3.

Note: Fully automated systems in this context are systems that perform git-ops style operations, such as synchronizing the state of resources from a live system into a git repository. These systems must not make arbitrary code changes without human peer-review.

Note: By default, all code in organization-owned repositories is assumed to affect production systems directly or indirectly and is thus, in scope for this statement.

3.1.4 Restricted Data, for example secrets, must not be stored in source code. Data that falls under the restricted classification is defined in the Data Classification and Handling Standard, which provides further relevant details.

Note: At time of publication of this Standard the relevant section in this other standard is 3.1.10 and for secrets item g.

3.1.5 Accounts associated with an Adobe email address on internet facing SCMs must only be used for Adobe business related work. Open-source contributions on behalf of Adobe are considered business related work.

3.1.6 Personal Access Tokens (PATs) must be rotated at least every 90 days.

3.2. Repository Administrators

3.2.1 Repository visibility must prevent unauthorized third-party access but should enable internal collaboration by default. Other standards, particularly the AIML Model Protection Standard, may require repositories to be private.

Exposure of the SCM Host	Repository Content	Default Visibility
Public facing	Proprietary code	Internal
Public facing	Open-source code	Public
Public or Internal facing	Primary Tier Large Language Models (LLMs), Generative AI code and related artifacts like model weights. Details are defined in the AIML Model Protection Standard	Private
Internal facing	Any other code	Public /Internal

NOTE: For Internal facing repositories there is no practical difference between "Public" and "Internal" and either setting is acceptable.

NOTE: This Standard only regulates source code security, but the same concept must be applied to other kinds of artifacts, for example in Adobe's Artifactory instances.

3.2.2 NOTE: Requirements for open-source repositories shall be found in the Open-Source Handbook. The default branch must point to an active branch.

3.2.3 Branch protection must be enabled for the default branch and all other long-lived branches in organization-owned repositories. Branch protection must be used to enforce statement 3.1.3.

NOTE*:* This statement uses GitHub terminology, other SCMs must implement equivalent controls.

3.2.3.1 'Allow force pushes' must be disabled to avoid accidental code overwrites.

3.2.3.2 'Require a pull request before merging' must be enabled to enforce peer review.

3.2.3.3 Administrators may 'allow specified actors to bypass required pull requests'. These actors must be generic utility accounts used solely for automation.

3.2.3.4 'Include administrators' must be enabled.

3.2.4 Administrators must limit write and administrative access to their repositories based on the principle of least privilege. Access to Git repositories must be audited quarterly.

3.2.5 Administrators must archive repositories once they are no longer in use. Non-archived repositories must be reviewed for archival every 6 months of inactivity.

3.2.5.1 Archived repositories must make use of the SCM's archival feature.

3.2.5.2 Archived repositories must be read-only.

3.2.5.3 Archived repositories must not be deployed to any dev/stage or production system.

3.2.5.4 Archived repositories are exempt from automated code scanning.

3.2.6 Administrators must associate repositories with a service id unless the repository contains only documentation or other non-executable, non-configuration text.

3.2.7 Additional requirements for public-facing repositories:

NOTE: Public facing, and especially open source, repositories must protect against malicious pull requests by third parties - including pull requests on forks.

3.2.7.1 Pull requests opened by third parties, whether directly in the repository or in forks of the repository, must not trigger automated build, test, or deploy processes of any kind. This must be enforced for GitHub Actions as well as any other build system like Jenkins or CircleCI.

3.2.7.2 A product team may mark a third party pull request as ready for automated testing by conducting a human-driven review. Afterwards the restrictions set forth in 3.2.7.1 no longer apply for the reviewed commits.

3.2.7.3 GitHub Secret scanning and push protection must be enabled.

3.3. Organization Administrators

3.3.1 Administrators of github.com organizations outside the EMUs scope must ensure that private and internal repositories are exclusively accessible by users with an active '@adobe.com' email address. Users must not have secondary email addresses on their accounts. This audit must happen at least quarterly.

3.3.1.1 Private organizations prefixed with "shared-" are exempt from 3.3.1 to allow private collaboration with third parties.

3.3.2 Administrators of organizations accessible without Adobe's Single-Sign-On (SSO, currently Okta) system must ensure that multi-factor-authentication is required during login. The MFA should be a time-based on time pad (TOTP), not a mobile phone number.

3.4. SCM System Administrators

3.4.1 Only employees in the engineering organization are allowed to access an SCM by default. All other employees, contractors, vendor-workers etc. must go through an explicit approval process to access an SCM.

3.4.1.1 Access granted in this fashion must be audited at least quarterly and revoked when no longer needed.

3.4.2 SCM systems must adhere to the restricted-level security bar of all security policies, independent of their data classification.

3.4.3 SCM administrators must, on a weekly basis, disable any webhooks that have no secret configured and thus are not authenticated.

3.4.4 SCM administrators must provide an audit log of all source code access events and enable security to block suspicious activity within 4 hours.

3.5. Utility/Generic Accounts and Automated Workflows

3.5.1 Automated workflows usable by more than one individual must make use of utility / generic accounts.

NOTE: This control primarily targets shared workflows in CI/CD systems and does not apply to local developer workstations.

3.5.2 Utility/generic accounts must not own organizations, unless listed below:

Generic Account	Owner
gitadmin	SCM team for all GitHub installations
assetgit, assetgit-adobe	Product and Software Security for Kodiak
uimtask	UIM / SailPoint IIQ for access management

Generic Account	Owner
jdkaspradmin	Jidoka team

NOTE: Accounts used on github.com with EMUs will be auto-suffixed with "_adobe" and included in this list.

3.6. Third Party Access

3.6.1 All third-party access to source code must be jointly approved by Product and Software Security (PaSS) and the Source Code Management (SCM) Team. All third parties, that have access to source code, must have an executed contract with Adobe, covering confidentiality and security, among others. Requests must be filed in the Jira project SCM. This especially applies to any kind of third-party build system, code review system, GitHub Apps, and similar tools. For approval, any third-party tool or system needs to achieve or exceed the requirements set forth in all relevant Adobe policies.

4. Future Revisions

This Standard does not yet mandate commit signing. We encourage teams across Adobe to experiment with it, so that we may consider commit signing for inclusion in future revisions of this Standard.

5. Definitions

Term	Definitions
EMU	Enterprise Managed Users, a feature on GitHub Enterprise Cloud that enables authentication via Adobe's Okta integration. Also see SSO
Default Branch	Usually 'main', the branch that is displayed by default in SCMs or checked out by default using Git
git	Open-source version control system
Internal Facing	A SCM is internal facing, if it is only accessible from the Adobe corporate network or via Adobe's zero-trust solutions. A repository is internal facing, if access control prevents anonymous users from accessing it.
Organization	Short term for GitHub Organization, a collection of repositories and various other meta data
PAT	Personal Access Token
Perforce	Commercial source code management system. At Adobe used only as a legacy archive in read-only mode
Primary Branch	A primary branch is the default target branch for all pull requests, usually 'main', and any other long-lived branch that is, directly or indirectly, released or deployed to a production system
Public Facing	A SCM is public facing, if it is accessible from the Internet. A repository is public facing, if anyone can access it from the Internet in a at least read-only fashion.
Repository	Short term for Git Repository, a collection of files and meta data in a versioned fashion
Service ID	Unique identifier assigned to a technical service in Adobe's service registry. Technical services may represent arbitrary entities, whether they are services, desktop or mobile apps, libraries, SDKs or other – in the widest sense - code-related constructs.

Term	Definitions
Kodiak	Kodiak is part of a suite of Adobe PaSS programs that are designed to minimize security risks in Adobe's services and products by being tightly integrated into the development workflow. Every pull request that is opened will be automatically scanned by Kodiak for security risks. If Kodiak identifies an issue, it will add a comment or inline annotation, just like a code reviewer would. Developers are informed about these issues to decide next steps. Kodiak encourages developers to implement fixes before merging these code changes.

6. Responsibilities

Group	Responsibilities
Product and Software Security (PaSS)	Collect audit data from SCM systems in an effort to ensure the described controls are in place or exceptions have been filed.
SCM administrators	Ensure users of their SCM fulfill all requirements set forth in this Standard. This includes providing automation to their SCM users to review repository privileges, fulfill the archival review requirement and similar statements above. SCM administrators are responsible for integrating their system with Kodiak so that PaSS can fulfill its duty described directly above. For SCM's used by at least 25% of Adobe's developers, the integration duty shifts to PaSS instead.
Users, Repository administrators, Organization administrators	Follow all requirements set forth in this Standard.

7. Governing Documentations

Adherence to the governing Policy and Standard referenced below are required to be compliant with this Standard:

- Information Security Policy - The Information Security Policy outlines the strategic objectives, requirements, and goals to secure data, systems, and products under Adobe's control. The policy establishes the tenets of the Information Security Management System (ISMS) of Adobe and addresses the expectations that it has from all Adobe workers.
- Inclusive Engineering Terminology Standard - The use of words with racist, sexist, or oppressive connotations, overtones, or history can make the reader feel hurt, traumatized, or unwelcome. Such words should not be used at Adobe in our code, our documentation, our user experiences, or anywhere else. This document identifies a set of established software terms that fall into this category and provides alternatives.

8. References

The documents mentioned in this Standard and listed below can be found on the Technology Policies and Standards Inside Adobe site:

- Data Classification and Handling Standard - The Data Classification and Handling Standard establishes that all data collected, processed, transmitted, stored, or destroyed by or on behalf of Adobe must be classified and then protected in accordance with its designated classification.

9. Document Properties

Coordinator	Ensures Review, Approval and Publication; Facilitates Discussions	Harrison Martorana, Technology Compliance Product Owner

Driver	Subject Matter Expert; Owner of Content; Works with Contributors	Florian Noeding, Principal, Security Architect
Approver	Approves Document	Bryan Payne, VP of Product and Software Security Jeff Sass, Director, Application Security
Accountable	Ultimately Responsible	Maarten Van Horenbeeck, Chief Security Officer
Contributor	Provides Recommendations; Subject Matter Expert; Critical Reviewer	Click here for Contributor list
Informed	Notified of Publications	Click here for Informed list

10. Document History

Version	Approval Date	Changes	Approved By
10.0	February 2024	Major Changes • Added the following sections: 3.1, 3.2, 3.3, 3.4, 3.5, 3.6 • Section 8 - Updated groups and responsibilities to be more accurate and clear Minor Changes • Sections 1 and 2 - Updated wording throughout section to be more clear and concise • Section 7 – Added/updated terms which are referenced within the document • Approver – Added Nubiaa Shabaka and Maarten Van Horenbeeck	Nubiaa Shabaka, VP, Chief Cybersecurity Legal and Privacy Officer Maarten Van Horenbeeck, Chief Security Officer
11.0	April 2025	No major changes Minor changes • Section 3.1.3 – Added 'Note: Fully automated systems in this context are systems that perform git-ops style operations, such as synchronizing the state of resources from a live system into a git repository. These systems must not make arbitrary code changes without human peer-review.' • Section 3.3.1 – Added 'Users must not have secondary email addresses on their accounts' • Added Section 3.3.2 'Administrators of organizations accessible without Adobe's Single-Sign-On (SSO, currently Okta) system must ensure that multi-factor-authentication is required during login. The MFA should be a time-based on time pad (TOTP), not a mobile phone number.' • Section 3.5.2 – Updated table to include rows for 'uimtask' and 'jdkaspradmin' generic accounts • Removed violations and exceptions sections which are duplicative content from the governing policy	Bryan Payne, VP of Product and Software Security Jeff Sass, Director, Application Security

Version	Approval Date	Changes	Approved By
		• Replaced approvers Nubiaa and Maarten with Bryan and Jeff	